



MASTER SERVICE AGREEMENT

between

Colosseum AG, Talstrasse 70, 8001 Zurich, Switzerland

(«**Colosseum**»)

and

Sonrisa Informatikai Kft, 1038 Budapest, Népfürdő u. 22., Hungary

(«**Service Provider**»)

(Colosseum and Service Provider together the «**Parties**» and each a «**Party**»)

Whereas:

- A. Colosseum wishes to procure certain services from the Service Provider.
- B. This master service agreement («**Agreement**») constitutes a framework that sets out the general terms and conditions which shall govern any statement of work describing in detail the services which the Parties may enter into («**Statement of Work**» or «**SoW**»).

1. Services

Service Provider agrees to perform work concerning software design and development and any additional services further defined on a case-by-case basis in the relevant Statement of Work («**Services**»). Where applicable, the deliverables, costs, milestones and Services shall also be defined in the Statements of Work. The Service Provider shall perform the Services with reasonable skill and care.

2. Compensation & Expenses

- 2.1 For providing the Services, Colosseum shall pay to Service Provider a compensation for the performance of the Services as outlined in the relevant Statement of Work. In addition, Colosseum shall reimburse Service Provider for any and all reasonable external expenses incurred by the Service Provider in the performance of the Services, provided that (i) such expenses have been pre-approved by Colosseum in writing and (ii) Service Provider can provide the original receipt upon request.
- 2.2 Unless agreed otherwise by the Parties in a SOW, Service Provider shall invoice Colosseum at the end of each month or based on the payment milestones agreed in the SOW(s). The invoice shall contain a description of the work done and include an overview of the hours spent per task in case the compensation is based on an hourly rate. The invoice shall be addressed to Colosseum's address indicated on this first page of this Agreement. Colosseum shall pay the invoice within 30 days from the date of receipt of a correctly addressed and undisputed invoice.

3. Representations & Warranties

Throughout the term of this Agreement, Service Provider represents and warrants that:

- a) it has the authority and right to enter into this Agreement and will only use the service of employees who have the professional capability and expertise to properly perform all the obligations hereunder;



- b) it has all necessary permits and licenses to perform the Services;
- c) it has adequate liability insurance to protect Service Provider, its employees if applicable, and Colosseum from any and all claims of any nature for damage, which may arise from its performance of this Agreement;
- d) it has a cyber liability insurance, including coverage for network security/data protection, covering liabilities for financial loss resulting or arising from acts, errors, or omissions, in rendering technology/professional services or in connection with the specific services and the Service Provider's breach of its security-related obligations described in this Agreement;
- e) it will not use Colosseum's name in the promotion of its services, unless agreed in writing by Colosseum;
- f) the work products resulting from the performance of the Services do not infringe any third party intellectual property rights.

4. Intellectual Property Rights & Work Products

Any and all intellectual property rights and work products created by Service Provider in the performance of the Services shall be assigned to Colosseum only upon full payment of all undisputed invoices related to the creation of such intellectual property rights and work products. Until such full payment is received by Service Provider, all intellectual property rights shall remain with Service Provider. Upon receipt of full payment, Service Provider agrees to assign, and hereby assigns, any and all such intellectual property rights and work products to Colosseum. If Service Provider cannot legally assign the intellectual property rights to Colosseum, Service Provider hereby grants an exclusive, royalty-free, fully paid-up, worldwide, unrestricted and transferable license, with the right to grant sublicenses, to use these intellectual property rights, such license becoming effective only upon receipt of full payment. For the avoidance of doubt, Service Provider shall not be allowed to use any work product thereafter for its own purposes.

5. Confidentiality

- 5.1 Except to the extent expressly permitted in this Agreement, each Party shall – during the term of this Agreement and for a period of 5 years thereafter – keep secret and in strictest confidentiality and not publish or otherwise disclose or use, directly or indirectly, for any purpose, any and all Confidential Information of the other Party received hereunder or hereinafter. Confidential Information may only be disclosed on a need to know basis to employees, officers and directors of the receiving Party as well as outside consultants, governmental entities and institutes, provided however, that these persons and entities will be bound by confidentiality obligations that are not less onerous than the confidentiality obligations of the receiving Party under this Agreement.
- 5.2 The confidentiality obligations imposed by this section shall not apply and the receiving Party shall not be deemed to have breached its confidentiality obligations if it can establish by written records that the information:
 - a) is or, after disclosure by a Party, becomes part of the public domain by publication or otherwise, through no act, negligence or fault of the other Party;
 - b) at the time of disclosure, is already in the other Party's rightful possession, without any limitation on use or disclosure, and the fact and propriety of such possession can be properly demonstrated by such other Party;
 - c) is rightfully made available to the other Party from a third party without restriction and without breach of any obligation of confidentiality between such third party and such other Party;
 - d) is developed by the other Party independently of any disclosure by such first Party, as evidenced by such other Party's written records.
- 5.3 Each Party may disclose Confidential Information to the extent that such disclosure is made in response to a valid order of a court of competent jurisdiction or a competent government authority. In that case, such Party shall first give notice to the other Party and give the other Party a reasonable opportunity to quash such order or to obtain a protective order requiring that the Confidential Information or documents that are the subject of such order be held in confidence



by such court or government authority or, if disclosed, be used only for the purposes for which the order was issued. If a disclosure order is not quashed or a protective order is not obtained, the Confidential Information disclosed in response to such court or governmental order shall be limited to that information that is legally required to be disclosed in such response to such court or governmental order.

- 5.4 **«Confidential Information»** as used in this section shall include, but is not limited to trade secrets, proprietary rights, drawings, inventions, know-how, processes, financial and business information, marketing plans, market studies, business plans, budgets, contracts, licensing arrangements and information relating to suppliers, clients, employees, or investors.

6. Data Protection

Should personal data be processed for the performance of any Services under a Statement of Work, the Parties agreed to the data processing agreement ("**DPA**") attached to this Agreement as Annex 1. The details of Service Provider's processing activities in the agreed Services will be specified in each Statement of Work according to the Schedule 1 of the DPA.

7. Liability

- 7.1 Neither Party shall be liable to the other for losses which are indirect, incidental, special or consequential, including loss of profits or revenue, business opportunity or use.
- 7.2 Notwithstanding anything in this Agreement to the contrary, neither Party's liability shall be limited in relation to losses arising from or relating to:
- a) fraud, misrepresentation, deliberate default or gross negligence by such party; or
 - b) any personal injury, in each case to the extent relating to any act or omission under this Agreement;
 - c) any liability which cannot legally be excluded or limited, or grossly negligent or deliberate failure by a party to comply with any applicable law;
 - d) indemnification under clause 8 below; or
 - e) breach of Confidentiality or any personal data breach.

8. Indemnification

Service Provider shall defend, indemnify and hold harmless Colosseum, as well as its respective directors, officers and employees, from and against any and all suits, proceedings, damages, losses and expenses (including reasonable attorney's fees and court costs) ("**Losses**") arising out of, relating to, or incurred as a result any claim or allegation by a third party that the Services infringes, misappropriates or violates any intellectual property rights of any third party.

9. Independent Contractors

The Parties are independent contractors and nothing contained in this Agreement will be construed to place them in the relationship of partners, principal and agent, employer/employee or joint venturers.

10. Term & Termination

- 10.1 This Agreement is made effective as of 22 May 2025 ("**Effective Date**") and remain in full force and effect unless terminated by either Party as provided herein.
- 10.2 Colosseum may terminate this Agreement or any SOW at any time by giving Service Provider 30 days prior written notice of termination. Termination of this Agreement automatically



terminates all SOWs hereunder, unless expressly agreed otherwise by the Parties in writing. A SOW may contain additional grounds upon which either Party may terminate the SOW.

- 10.3 Each Party may terminate this Agreement with immediate effect in case the other Party is in material breach or material default in the performance of any of its obligations hereunder and such defaulting Party fails to cure such default within 30 days after receipt of the written default notice.
- 10.4 Each Party may terminate this Agreement if the other Party shall be or becomes insolvent, or a petition in bankruptcy or some equivalent under applicable laws shall be filed by or against it, or if the other Party shall make any assignment for the benefit of creditors, or a receiver of the property or a substantial portion thereof of the Party shall be appointed, or if the other Party shall seek protection under any laws or regulations the effect of which is to suspend or impair the rights of its creditors, which termination shall be effective immediately upon notice to such other Party.
- 10.5 Colosseum may terminate this Agreement in the event of any acquisition of Service Provider by a third party or change in the direct or indirect ownership, interest or control of Service Provider.

11. Anti-Bribery Clause

- 11.1 Service Provider will conduct all activities under this Agreement in accordance with any and all applicable laws and good business ethics, including anti-corruption laws. Service Provider represents and warrants that its employees, agents, officers, or other members of its management shall not make any payment or provide any benefit, either directly or indirectly, to government or political party officials, candidates for public office, publicly employed persons (e.g., doctors in public hospitals) or other recipients in connection with the performance of the Services where such payment would constitute a violation of any applicable laws.
- 11.2 Any breach of the provisions of this section by Service Provider will be deemed a material breach of this Agreement and grant Colosseum the right to immediately terminate this Agreement. Without limitation of the foregoing, Service Provider shall indemnify and hold Colosseum harmless from and against any and all liabilities (including all costs and attorney fees associated with investigating or defending against such claims) that may result from these acts or omissions of Service Provider or third parties acting on Service Provider's behalf.

12. Miscellaneous

- 12.1 No Waiver. Either Party's failure to enforce, at any time or for any period of time, any provision of this Agreement, or to exercise any right or remedy shall not constitute a waiver of that provision, right or remedy or prevent it from enforcing any or all provisions of this Agreement and exercising any rights or remedies. To be effective any waiver must be in writing. The rights and remedies provided herein are cumulative and do not exclude any other right or remedy provided by law or otherwise available except as expressly set forth herein.
- 12.2 Assignability. This Agreement or any rights or obligations hereunder shall not be assigned by any Party to any third party without the prior written consent of the other Party. Colosseum may, however, assign this Agreement to any of its affiliates without the consent of Service Provider.
- 12.3 No Subcontracting. Service Provider may subcontract its obligations under this Agreement. In all such cases, Service Provider shall retain full contractual responsibility for all such subcontracted work to the same extent as if the work had been performed by Service Provider itself.
- 12.4 Entire Agreement and Order of Precedence. This Agreement represents the entire agreement between the Parties in respect of its subject matter. The Annex referred to in this Agreement is an integral part of this Agreement. If there is a conflict or inconsistency between the terms and conditions of this Agreement and the terms and conditions of any Statement of Work, the terms



and conditions of the Statements of Work shall prevail. In case of discrepancies between 2 Statements of Work, the most recent one shall prevail.

- 12.5 Written-Form-Clause. This Agreement and this written-form-clause may only be modified, released, discharged, abandoned or otherwise terminated in writing and signed by both Parties.
- 12.6 Governing Law, Jurisdiction. This Agreement will be governed by and interpreted in accordance with the laws of Switzerland under exclusion of the United Nations Convention on Contracts for the International Sale of Goods. The exclusive venue for all disputes arising out of or in connection with this Agreement and its performance and termination shall be Zurich, Switzerland.
- 12.7 Severability. If any provision of this Agreement is or becomes invalid, ineffective or unenforceable, the remaining provisions of this Agreement shall remain in full force and effect. The Parties agree to replace the invalid, ineffective or unenforceable provision with a valid, effective or enforceable one, the content of which most closely approximates their original economic and legal intent. The same applies in case of an unintentional contractual gap.
- 12.8 Execution. This Agreement may be executed in two or more counterparts (including electronic transmission, such as scanned copies), each of which shall be deemed an original, and all of which together shall constitute one and the same instrument. This Agreement, and any amendment hereto, may be executed electronically, in particular by using digital signature, and each electronically signed and/or scanned copy shall be deemed an original copy.

Colosseum AG

Signed by:

Daniel Fehr.

A518B52B86024CF

Name: Daniel Fehr

Title: CFO

Date: 18.07.2025

Signiert von:

Raoul Dias

3915FDA6676A4A2

Name: Raoul Dias

Title: Chief HR & Legal Officer

Date: 18.07.2025

Sonrisa Informatikai Kft.

Signed by:

Miklós Szurdi

1455EE3BE88F410

Name: Szurdi Miklós

Title: CEO

Date: 25.07.2025

Annex 1 – Data Processing Agreement

This Data Processing Agreement (“**Agreement**”) is made and entered into between

Colosseum AG, Talstrasse 70, 8001 Zurich, Switzerland (UID: CHE-428.972.946), which has negotiated this Agreement on behalf of each Colosseum Group Company (“**Controller**”);

and

Sonrisa Informatikai Kft., 1038 Budapest, Népfürdő u. 22., Hungary (tax number: 13873222-2-41) (the “**Processor**”).

each referred to as a “**Party**” and together as the “**Parties**”.

WHEREAS:

- (A) Parties have entered into the Master Services Agreement on 22 May 2025 in relation to IT Services which will be defined on a case-by-case basis in the relevant Statement of Work (the “**Principal Agreement**”);
- (B) the Processor obtains personal data within the meaning of Article 28 of the GDPR within the context of the execution of the Principal Agreement and will process this Personal Data (as defined below) within the scope of this Agreement for the benefit of the Controller;
- (C) under the Applicable Data Protection Laws (as defined below), the Parties are obliged to enter into an agreement to ensure the protection of Personal Data.

IT IS AGREED AS FOLLOWS:

1 DEFINITIONS

In this Agreement, the following terms shall have the meanings set out below and cognate terms shall be construed accordingly:

- 1.1 “**Agreement**” means this data processing agreement;
- 1.2 “**Applicable Data Protection Laws**” means the Swiss Federal Act on Data Protection of 25 September 2020, the GDPR and applicable national laws implementing or supplementing the GDPR, the UK 2018 Data Protection Act and any new piece of legislation amending or replacing such laws and acts;
- 1.3 “**Colosseum Group Company**” means all of Controller’s direct or indirect subsidiaries and subsidiary undertakings;
- 1.4 “**General Data Protection Regulation (GDPR)**” means Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC;



- 1.5 **“Personal Data Breach”** means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to the Personal Data;
- 1.6 **“Principal Agreement”** has the meaning as described in recital (A).
- 1.7 The terms **“Data Subject”**, **“Personal Data”**, and **“Process/Processing”** shall have the same meaning as in the GDPR, and their cognate terms shall be construed accordingly.
- 1.8 Capital terms and abbreviations used but not defined herein shall have the same meaning as set out in the Principal Agreement

2 PROCESSING OF CONTROLLER PERSONAL DATA

- 2.1 Parties acknowledge that in the performance of the Principal Agreement, the Processor may Process Personal Data on behalf of the Controller, as further detailed in each Statement of Work according to Schedule 1 hereto. The Controller may make reasonable amendments to Schedule 1 by written notice to the Processor from time to time as Controller reasonably considers necessary.
- 2.2 When Processing the Personal Data, the Processor shall:
- comply with all Applicable Data Protection Laws, the Principal Agreement and this Agreement; and
 - not Process Personal Data other than on the Controller’s documented instructions, unless required to do so by European Union or Member State Law to which the Processor is subject. In such a case the Processor shall inform the Controller of that legal requirement before Processing the Personal Data, unless that same requirement prohibits such information on important grounds of public interest. The Processor shall document the instructions of the Controller.
- 2.3 The Processor shall not use Personal Data to approach persons or companies to which these Personal Data relate, such as for telemarketing purposes, personal visits and/or any other contact with these persons or companies, unless Parties have agreed otherwise in the Principal Agreement.
- 2.4 The Processor shall not add the Personal Data to its own files or files of third parties managed by the Processor, sell, resell to third parties, use for commercial or otherwise personal use or use by or on behalf of third parties. This obligation applies for the entire duration of the Principal Agreement and after its completion.

3 PROCESSOR’S PERSONNEL

- 3.1 The Processor shall ensure that (i) only persons working on behalf of the Processor who require access to the Personal Data for the performance of their duties are granted access to the Personal Data and that such access is only granted for the performance of this Agreement and (ii) that these persons shall Process the Personal Data in accordance with the documented instructions given by the Controller and (iii) that these persons are bound to confidentiality with respect to the Personal Data. The Processor’s obligations shall continue after the termination of this Agreement.

4 SUB-PROCESSING

- 4.1 The Processor shall not engage (or disclose any Personal Data to) a sub-processor without obtaining the Controller's prior written consent.
- 4.2 The Processor shall ensure that each sub-processor engaged by the Processor, if any, is bound to comply with all the obligations under this Agreement, as imposed to the Processor, in particular by providing sufficient guarantees to implement appropriate technical and organizational measures in such a manner that the Processing will meet the requirements of the Applicable Data Protection Laws.
- 4.3 Subject to clause 4.1, if the sub-processor is based in a country which does not provide an adequate level of data protection according to Swiss or EU standards:
- the Processor shall make sure that it implements the necessary safeguards foreseen by the Applicable Data Protection Laws, in particular enter into European Commission Standard Contractual Clauses (SCC) and/or Binding Corporate Rules (BCR), subject to any amendments required by Swiss law, where applicable, with such sub-processor for the Personal Data provided by Controller.
- 4.4 The Processor shall disclose to the Controller any country where the Personal Data is being disclosed to as provided for in clause 19(4) of the Swiss Federal Act on Data Protection.
- 4.5 The Processor shall remain fully liable to the Controller for Processing of the Personal Data in accordance with this Agreement, the Principal Agreement and Applicable Data Protection Laws.
- 4.6 Subject to the terms of clause 4.1, the Processor shall inform the Controller of any intended changes concerning the engagement or replacement of any sub-processors, giving the Controller the possibility to timely object hereto.

5 COOPERATION OBLIGATIONS OF THE PROCESSOR

- 5.1 The Processor shall, at no additional cost to the Controller, co-operate with the Controller to comply with its obligations under the Applicable Data Protection Laws with respect to the Personal Data, including meeting the requests of Data Subjects, any data protection impact assessments and prior consultations with or requests from Supervisory Authorities or other competent data privacy authorities.
- 5.2 The Processor shall:
- 5.2.1 Without undue delay, and ultimately within twelve (12) hours after receipt, notify Controller if it receives:
- a request from a Data Subject with regard to Personal Data;
 - a (information) request from the Supervisory Authorities or other competent data privacy authorities relating to the Processing of the Personal Data; or
 - a third-party complaint or request relating to the obligations of the Processor and/or the Controller with respect to the Personal Data under the Applicable Data Protection Laws;
 - any other communication relating directly or indirectly to the Processing or protection

of the Personal Data; and

not respond to a request, except on the documented instructions of the Controller or as required by the Applicable Data Protection Laws, in which case the Processor shall to the extent permitted by that law inform Controller of that legal requirement before it responds to a request.

6 TRANSFERS

6.1 Every Processing of Personal Data on behalf of the Controller shall take place within the European Economic Area (EEA) and Switzerland, unless the Controller has given prior written permission to the Processor to have the Processing take place outside the EEA or Switzerland. The Controller is entitled to attach conditions to this permission, including the obligation of the Processor to take appropriate measures.

6.2 Should the Controller give prior written permission to the Processor to have the Processing take place outside the EEA or Switzerland, clauses 4.3 to 4.5 of this Agreement shall apply to this clause analogously.

7 SECURITY

7.1 The Processor shall keep the Personal Data strictly confidential.

7.2 The Processor shall not disclose the Personal Data to a third party without the prior written consent of the Controller.

7.3 Taking into account the state of the art, the sensitivity of the Personal Data, the costs of implementation and the nature, scope, context and purposes of Processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the Processor shall in relation to the Personal Data implement appropriate technical and organizational measures to ensure a level of security appropriate to that risk, including, as appropriate, the measures referred to in Article 32 of the GDPR.

7.4 The Processor shall provide an overview and description of the (technical, logical and organizational) security measures put in place in Schedule 2 to this Agreement and confirms that the measures in clause 7.3 of this Agreement provide an appropriate security level and meet the requirements for security measures pursuant to the Applicable Data Protection Laws. Schedule 2 will be reviewed and updated by the Processor from time to time, in order to ensure a continuous level of security. Any such update of Schedule 2 will be communicated to the Controller in writing without delay.

7.5 The Controller has the right to add certain security measures to Schedule 2 as Controller reasonably considers necessary to comply with the Applicable Data Protection Laws, to which security measures the Processor shall abide.

8 PERSONAL DATA BREACH

8.1 The Processor shall notify the Controller in writing without undue delay, and ultimately within twelve (12) hours upon becoming aware of (indications of) a Personal Data Breach affecting Personal Data, providing Controller with sufficient information to allow it to meet any obligations to report to or inform the Supervisory Authority (or other competent data privacy authorities) and/or the Data Subjects of a Personal Data Breach.

- 8.2 Such notification shall as a minimum:
- 8.2.1 describe the nature of the (potential) Personal Data Breach, the categories and numbers of Data Subjects concerned, and the categories and numbers of Personal Data records concerned;
 - 8.2.2 communicate the name and contact details of the Processor's data protection officer or other relevant contact from whom more information may be obtained;
 - 8.2.3 describe the likely consequences of the Personal Data Breach;
 - 8.2.4 describe the measures taken or proposed to be taken to address the Personal Data Breach;
 - 8.2.5 include a copy of the forensic report from any investigations and/or audit and any relevant documental evidence of the potential Personal Data Breach.
- 8.3 The Processor shall co-operate with the Controller and take all such reasonable commercial steps as are directed by the Controller to assist in the investigation, mitigation and remediation of each such Personal Data Breach.

9 AUDIT RIGHTS

- 9.1 The Processor shall make available to the Controller on request all information necessary to demonstrate compliance with the Applicable Data Protection Laws.
- 9.2 The Processor shall allow audits, including inspections, by the Controller or a representative appointed by the Controller with respect to the Processor's Processing of Personal Data, after the Processor has been notified at least seven (7) days in advance. The Processor shall provide the Controller or its representative with access to its premises (to the extent relevant to the audit or inspection), systems and materials.
- 9.3 The costs of such audit shall be for the account of the Controller, unless the (results of the) audit reveal(s) that the Processor has violated its obligations under the Applicable Data Protection Laws.
- 9.4 The Processor shall rectify the shortcomings, identified as a result of such an audit, at its own expense within a reasonable period to be determined by the Controller.
- 9.5 The Processor shall immediately inform the Controller if, in its opinion, an instruction (possibly) infringes with the Applicable Data Protection Laws.

10 TERM AND TERMINATION

- 10.1 This Agreement is entered into for the duration of the Principal Agreement.
- 10.2 Any obligation arising from this Agreement that by nature has post-contractual effect, including, but without limitation to the Processor's obligations under clause 9 of this Agreement, shall continue to be in effect after the termination of this Agreement.

11 DELETION OR RETURN OF PERSONAL DATA

- 11.1 At first request of the Controller upon expiration or termination of the Principal Agreement, the Processor shall, at the choice of the Processor, either delete all Personal Data Processed on behalf of the Controller and certify to the Controller that it has done so, or, return all Personal Data to the Controller and delete existing copies unless Union or Member State law requires

storage of the Personal Data.

- 11.2 As long as the Processor still possesses copies of Personal Data, the Processor shall fully comply with the provisions of this Agreement.

12 MISCELLANEOUS

- 12.1 If and to the extent that a provision in the Principal Agreement and/or general conditions attached thereto between the Parties conflicts with any provision in this Agreement, the provisions in this Agreement shall prevail.
- 12.2 This Agreement may be amended only by written agreement between the Parties, without prejudice to clause 2.1 above.
- 12.3 Parties shall make amendments to this Agreement that due to changes are necessary to maintain compliance with the Applicable Data Protection Laws.
- 12.4 None of the rights and obligations under this Agreement can be assigned or transferred by the Processor to any third party without the prior written consent of the Controller. The Controller can however assign this Agreement without having to obtain the Processor's prior consent.
- 12.5 If any provision of this Agreement is declared void or unenforceable by any court or tribunal of competent jurisdiction, the other provisions of this Agreement shall remain to be of effect, unless the latter provisions must be deemed to be indissolubly connected with the void or unenforceable provision. In the event that the other provisions remain valid, both Parties shall endeavor to replace the void or unenforceable provision by a valid provision which reflects the Parties' original intent to the greatest possible extent.
- 12.6 The costs relating to the execution of this Agreement are included in the prices and fees as agreed in the Principal Agreement, unless otherwise provided in this Agreement.

13 GOVERNING LAW

- 13.1 This Agreement shall be governed by and construed in accordance with the laws of Switzerland.
- 13.2 For all disputes arising in connection with this Agreement, the Parties hereto submit to the exclusive jurisdiction of the courts of Zurich, Switzerland.

SCHEDULE 1

DETAILS OF PROCESSING OF PERSONAL DATA

This Schedule 1 includes certain details of the Processing of the Personal Data as required by Article 28(3) GDPR.

- 1 Subject matter and duration of the Processing of Personal Data**
- 2 The nature and purpose of the Processing of Personal Data**
- 3 The categories of Data Subject to whom the Personal Data relates**
- 4 The types of Personal Data to be Processed**



SCHEDULE 2

SECURITY MEASURES IMPLEMENTED BY THE PROCESSOR

1. General description of security measures and appropriate security level

Processor maintains a comprehensive Information Security Management System (ISMS) aligned with ISO 27001 standards. The organization's security policies and procedures ensure confidentiality, integrity, and availability of data while complying with relevant legal and regulatory requirements.

Key measures include:

- Information Security Policies: Reviewed annually and enforced across all departments.
- Access Control & Identity Management: Ensuring only authorized personnel access sensitive systems.
- Data Protection & Encryption: Implemented for data at rest and in transit.
- Continuous Monitoring: Security incidents, anomalies, and vulnerabilities are actively tracked.
- Third-Party Risk Management: Security evaluations of suppliers and partners are conducted regularly.

The security level is high, meeting industry standards for data protection, IT security, and regulatory compliance.

2. IT Technical security measures taken

Processor employs robust technical security measures to protect infrastructure, applications, and data. These include:

- Network Security:
 - Enforced firewall rules, VPN access, and network segregation to protect sensitive systems.
 - Web filtering to reduce exposure to malicious content.
- Endpoint & Access Security:
 - Multi-Factor Authentication (MFA) enforced for cloud and internal systems.
 - Identity lifecycle management (onboarding & offboarding process).
- Threat Protection & Monitoring:
 - CrowdSec & Zabbix used for security monitoring.
 - Nessus & OpenVAS used for vulnerability scanning and mitigation.
- Backup & Redundancy:
 - Daily incremental backups & weekly full backups stored securely.
 - AWS Cloud & VMware Veeam used for backup and disaster recovery.
- Incident Response & Forensics:
 - Security incidents are logged, analyzed, and mitigated using Jira & Wazuh SIEM.
 Incident classification is based on MITRE ATT&CK threat intelligence.

3. Organizational security measures taken

Processor ensures organizational security through defined roles, responsibilities, and compliance policies:

- Security Governance & Policies:
 - The ISMS Manual defines all security policies, roles, and procedures.
 - Information security roles are included in employee job descriptions.
 - Regular risk assessments and audits ensure compliance.
- Access & Identity Management:



- Strict role-based access control (RBAC) policies.
 - LDAP, EntraID, and Keepass/Bitwarden used for authentication & credential storage.
- Security Awareness & Training:
 - Mandatory security training for all employees, with periodic refresher sessions.
 - Specialized training for privileged users and IT security teams.
- Supplier & Vendor Security Management:
 - Supplier agreements include security compliance requirements.
 - Vendors are evaluated using risk assessments & background checks.
- Incident Handling & Compliance:
 - Formalized disciplinary process for security breaches.
 Incident reporting mechanisms in place through Jira & security monitoring tools.

4. Logical security measures taken

Logical security measures ensure controlled access to IT systems, networks, and data:

- Access Controls & Authentication:
 - Privileged access management (PAM) with strict admin account policies.
 - Multi-Factor Authentication (MFA) enforced for all sensitive systems.
- Secure Development & Change Management:
 - Code review & approval workflows using SonarQube, GitLab & CI/CD pipelines.
 - Development, testing, and production environments are strictly separated.
- Data Transfer & Encryption:
 - HTTPS/TLS, VPN & IPsec tunnels enforced for secure data transfer.
 - M365 encryption & Azure Key Vault used for cryptographic key management.
- Logging & Monitoring:
 - SIEM logging (Wazuh, Nginx reverse proxy) for access and security logs.
 - Scheduled security audits for compliance.
- Endpoint & Workstation Security:
 - Enforced endpoint encryption (Bitlocker, FileVault).
 All devices use centralized patch management (ManageEngine, Microsoft Defender).

5. Internal policies, procedures, back-ups and disaster recovery plans that are in place

Processor follows structured backup, business continuity (BCP), and disaster recovery (DRP) policies to prevent data loss:

- Backup & Recovery Strategy:
 - Daily backups (incremental) & weekly full backups stored securely.
 - Cloud backup providers: AWS (Tier 1), VMware Veeam (Tier 2 & 3).
 - Regular disaster recovery testing ensures system resilience.
- Disaster Recovery (DR) & Business Continuity (BCP) Plans:
 - DRP includes predefined incident response plans for cyber incidents.
 - Business Impact Analysis (BIA) conducted to define critical assets & recovery times.
 - Finance and Sales business continuity plans (BCP) are in place.
- Change Management & Security Audits:
 - Configuration Management Database (CMDB) tracks all IT changes.
 - Security testing (Nessus, Greenbone, BurpSuite) before deployments.
 Audit processes documented & reviewed annually.

6. Coverage of cyber risks by insurance policies

At present, Processor does not maintain a dedicated cyber risk insurance policy. However, the company continuously evaluates its risk management framework and may consider implementing cyber insurance coverage as part of its ongoing security and compliance strategy.